ETSI TS 104 275 V1.1.1 (2026-09)



TECHNICAL SPECIFICATION

Securing Artificial Intelligence (SAI); Application of Baseline Cyber Security Requirements for AI Models and Systems principles to Generative AI; Preventing Harm from Deepfakes

Reference
DTS/SAI-0031

Keywords
artificial intelligence, GenAI, trustworthy AI

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.
By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter.
Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights 5
Foreword 5
Modal verbs terminology 5
Introduction 5
1 Scope 7
2 References 7
2.1 Normative references 7
2.2 Informative references 7
3 Definition of terms, symbols and abbreviations 8
3.1 Terms 8
3.2 Symbols 9
3.3 Abbreviations 9
4 Overview of Generative AI and Deepfakes 10
4.1 What is Generative Artificial Intelligence (GenAI) 10
4.2 Uses of GenAI 10
4.3 Overview of Deepfakes 10
5 AI Security Principles and Provision Extensions 11
5.1 Secure Design 11
5.1.1 Principle 1: Raise awareness of AI security threats and risks 11
5.1.2 Principle 2: Design the AI system for security as well as functionality and performance 11
5.1.3 Principle 3: Evaluate the threats and manage the risks to the AI system 11
5.1.4 Principle 4: Enable human responsibility for AI systems 11
5.2 Secure Development 12
5.2.1 Principle 5: Identify, track and protect the assets 12
5.2.2 Principle 6: Secure the infrastructure 12
5.2.3 Principle 7: Secure the supply chain 12
5.2.4 Principle 8: Document data, models and prompts 12
5.2.5 Principle 9: Conduct appropriate testing and evaluation 13
5.3 Secure Deployment 13
5.3.1 Principle 10: Communication and processes associated with End-users and Affected Entities 13
5.4 Secure Maintenance 13
5.4.1 Principle 11: Maintain regular security updates, patches and mitigations 13
5.4.2 Principle 12: Monitor the system's behaviour 13
5.5 Secure End of Life 13
5.5.1 Principle 13: Ensure proper data and model disposal 13
Annex A (informative): Overview of Detection and Prevention of GenAI Deepfakes 15
A.1 Introduction 15
A.2 Reporting and Removal of Deepfake material 15
Annex B (informative): Trustworthy AI 17
B.1 Overview 17
B.2 Mapping of GenAI to Trustworthy AI 18
B.2.1 Overview 18
B.2.2 Table of Mapping 18
Annex C (normative): Extension Provisions for Conformance assessment for AI 21
C.1 Overview 21
C.2 Extension Provisions Test scenarios for AI 21
C.2.1 TSO 5.1.1: Raise awareness of AI security threats and risks 21

C.2.1.1 Test Case GenAI Deepfake Extension Provision 5.1.1.-1 21
C.2.2 TSO 5.1.2: Design the AI system for security as functionality and performance 21
C.2.2.1 Test Case GenAI Deepfake Extension Provision 5.1.2.-1 21
C.2.3 TSO 5.1.3: Evaluate the threats and manage the risks to the AI system 22
C.2.3.1 Test Case GenAI Deepfake Extension Provision 5.1.3.-1 22
C.2.3.2 Test Case GenAI Deepfake Extension Provision 5.1.3.-2 22
C.2.4 TSO 5.1.4: Enable human responsibility for AI systems 23
C.2.4.1 Test Case GenAI Deepfake Extension Provision 5.1.4.-1 23
C.2.4.2 Test Case GenAI Deepfake Extension Provision 5.1.4.-2 23
C.2.5 TSO 5.2.1 Identify, track and protect the assets 24
C.2.5.1 Test Case GenAI Deepfake Extension Provision 5.2.1.-1 24
C.2.6 TSO 5.2.4 Document data, models and prompts 24
C.2.6.1 Test Case GenAI Deepfake Extension Provision 5.2.4.-1 24
C.2.7 TSO 5.3.1 Communication and processes associated with End-users and Affected Entities 25
C.2.7.1 Test Case GenAI Deepfake Extension Provision 5.3.1.-1 25
History 26

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM**® and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

This Technical Specification (TS) has been produced by ETSI Technical Committee Securing Artificial Intelligence (SAI).

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

Artificial Intelligence (AI) is transforming our daily lives. As the technology continues to evolve and be embedded in people's lives, it is crucial that efforts are taken to protect AI systems from growing cyber security threats. Special focus on the cybersecurity of Artificial Intelligence (AI) is important due to its distinct differences compared to traditional software. These characteristics include security risks such as data poisoning, model obfuscation, indirect prompt injection and operational differences associated with data management.

The present document utilizes existing good practice in the AI and cyber security landscape alongside novel measures to provide a set of targeted high-level principles and provisions at each stage of the AI lifecycle. The objective of the present document is to provide stakeholders in the AI supply chain with clear baseline security requirements to help protect AI systems. With this present document applying the principles from ETSI EN 304 223 [1] to Generative AI (GenAI) to prevent them being used to produce harmful deepfake material.

The present document separates principles and requirements into five phases. These are secure design, secure development, secure deployment, secure maintenance and secure end of life. Relevant standards and publications are signposted at the start of each principle to highlight links between the various documents and the present document.

This is not an exhaustive list.

NOTE: The principles, described in the present document, can also be mapped to the life cycle stages described in ISO/IEC 22989 [i.3] as follows:

- the secure design and development principles can be applied during the Design and development life cycle stage;
- the secure deployment principles can be applied during the Deployment stage;
- secure maintenance to the Operations and monitoring stage; and
- secure end of life during the Retirement stage.

Information on the AI lifecycle and implementation examples is given in ETSI TR 104 128 [i.2].

ETSI TS 104 216 [i.4] provides guidance on how to evaluate and validate AI systems in accordance with the provisions of the present document.

ETSI TR 104 159 [i.5] provides an overview of GenAI to help understand the problem and the type of measures that can be implemented to prevent harm.

1 Scope

The present document is a domain-specific focus application of the ETSI EN 304 223 [1] principle for base cybersecurity requirements for AI models and systems for Generative AI. The present document is focusing on the subject of deepfakes, which includes the issues of misinformation, disinformation, loss of confidentiality, copyright, IPR and the training/source material for LLMs. Also, the present document is including more prescriptive specifications for this domain extension to ETSI EN 304 223 [1] when necessary.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the ETSI docbox.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

[1] ETSI EN 304 223 (V2.1.1): "Securing Artificial Intelligence (SAI); Baseline Cyber Security Requirements for AI Models and Systems".

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

[i.1] What is Gen AI? Generative AI explained.

[i.2] ETSI TR 104 128: "Securing Artificial Intelligence (SAI); Guide to Cyber Security for AI Models and Systems".

[i.3] ISO/IEC 22989:2022: "Information technology — Artificial intelligence — Artificial intelligence concepts and terminology".

[i.4] ETSI TS 104 216: "Securing Artificial Intelligence (SAI); Conformance assessment for AI (EN 304 223)".

[i.5] ETSI TR 104 159 (V1.1.1): "Securing Artificial Intelligence (SAI); Understanding and Preventing Harm from Generative AI".

[i.6] ITU-T SG17: "Security Guidelines for Generative Artificial Intelligence Application Service".

[i.7] ITU-T SG17: "Implementation guidelines for digital watermarking".

[i.8] European Parliamentary Research Service: "Tackling deepfakes in European policy", 2021.

[i.9] Increasing Threat of Deepfake Identities.

[i.10] ETSI TS 104 119 (2025-10): "Methods for Testing & Specification (MTS); AI Testing Guidelines for Documentation of AI-enabled Systems".

[i.11] Hackers exploit generative AI; 2024; Centre for Cyber Security.

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the following terms apply:

adversarial attack: attempt to manipulate an AI model by introducing specially crafted inputs to cause the model to produce errors or unintended outcomes

AI system: engineered system that generates outputs such as content, forecasts, recommendations or decisions for a given set of human-defined objectives

Application Programming Interface (API): set of tools and protocols that allow different software systems to communicate and interact

data poisoning: type of adversarial attack where malicious data is introduced into training datasets to compromise the AI system's performance or behaviour

disinformation: false information that is deliberately spread to deceive or manipulate others

NOTE: It is done on purpose to influence opinions or actions

generative artificial intelligence: deep-learning models that can generate high-quality text, images, and other content based on the data they were trained on

guardrails: predefined constraints or rules implemented to control and limit an AI system's outputs and behaviours, ensuring safety, reliability, and alignment with ethical or operational guidelines

harm: to hurt someone or damage something

inference: reasoning by which conclusions are derived from known premises

NOTE 1: In AI, a premise is either a fact, a rule, a model, a feature or raw data.

NOTE 2: The term "inference" refers both to the process and its result.

input data: data for which an AI system calculates a predicted output or inference

malicious: intent to cause harm or damage

machine learning algorithm: algorithm to determine parameters of a machine learning model from data according to given criteria

machine learning model: mathematical construct that generates an inference or prediction based on input data or information

model inversion: privacy attack where an adversary infers sensitive information about the training data by analysing the AI model's outputs

model training: process to determine or to improve the parameters of a machine learning model, based on a machine learning algorithm, by using training data

misinformation: wrong information or information intended to deceive

prediction: primary output of an AI system when provided with input data or information

NOTE 1: Predictions can be followed by additional outputs, such as recommendations, decisions and actions.

NOTE 2: Prediction does not necessarily refer to predicting something in the future.

NOTE 3: Predictions can refer to various kinds of data analysis or production applied to new data or historical data (including translating text, creating synthetic images or diagnosing a previous power failure).

prevention: act of stopping something from happening or of stopping someone from doing something

prompt: input provided to an AI model, often in the form of text, that directs or guides its response

NOTE: Prompts can include questions, instructions, or context for the desired output.

risk assessment: process of identifying, analysing and mitigating potential threats to the security or functionality of an AI system

sanitization: process of cleaning and validating data or inputs to remove errors, inconsistencies and malicious content, ensuring data integrity and security

system prompt: predefined input or set of instructions provided to guide the behaviour of an AI model, often used to define its tone, rules, or operational context

threat modelling: process to identify and address potential security threats to a system during its design and development phases

training: process of teaching an AI model to recognize patterns, make decisions, or generate outputs by exposing it to labelled data and adjusting its parameters to minimize errors

training data: data used to train a machine learning model

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

AI	Artificial Intelligence
API	Application Programming Interface
CSAM	Child Sexual Abuse Material
DMA	Diffusion Model Architecture
FBI	Federal Bureau of Investigation
GAN	Generative Adversarial Model
GDPR	General Data Protection Regulation
GenAI (GAI)	Generative Artificial Intelligence
IC3	Internet Crime Complaint Centre
ITU-T	International Telecommunication Union Telecommunication Standardization Sector
LLM	Large Language Model
ML	Machine Learning
NCII	Non-Consensual Intimate Image
TSO	Test Scenario

4 Overview of Generative AI and Deepfakes

4.1 What is Generative Artificial Intelligence (GenAI)

Generative Artificial Intelligence (generative AI, GenAI, or GAI) is a subset of artificial intelligence that can use Generative Adversarial Models (GANs) or Diffusion Model Architecture (DMAs) to produce text, images, videos, or other forms of data [i.1]. Instead of being based on the input, these models learn the underlying patterns and structures of their training data and use them to produce new data, instead of being based on the input, often in the form of natural language prompts. In general, Gen AI uses algorithms to organize large, complex data sets into potentially meaningful clusters of information to create new content, including text, images and audio, in response to a query or prompt.

NOTE: The issues of harm, the threats and mitigations that apply to GenAI are also relevant to Agentic AI, as Agentic AI is an evolution of GenAI.

Related work is also under development in ITU-T SG17 [i.7] on 'Security guidelines for Generative Artificial Intelligence Application Service' [i.6] and 'Implementation guidelines for digital watermarking', which complement the subjects discussed in the present document.

4.2 Uses of GenAI

Generative AI is used across various industries, including - but not limited to - software development, healthcare, finance, entertainment, customer service, sales and marketing, art, writing, fashion, and product design. Some examples of use cases of GenAI are:

1) Text: capable of natural language processing, machine translation, and natural language generation and can be used as a foundation model for other tasks.

2) Code: Generate source code for programs.

3) Images: Commonly used for text-to-image generation and neural style transfer.

4) Audio: produces natural-sounding speech synthesis and text-to-speech capabilities.

5) Video: Can generate temporally coherent, detailed and photorealistic video clips.

4.3 Overview of Deepfakes

A type of threat falling under the greater and more pervasive umbrella of synthetic media utilizes a form of artificial AI/ML to create believable, realistic videos, pictures, audio, and text of events which never happened [i.8].

Deepfakes are videos, audio, or images that seem real but have been manipulated with AI. They have been used to try to influence elections and to create non-consensual pornography, and also used to develop child sexual abuse material, low-cost deepfake adverts and synthetic terrorist content. The malicious use of deepfakes can cause an erosion of trust in elections, spread disinformation, undermine national security and empower harassers.

It can combine both sexual harassment and cyberbullying, which can be incredibly traumatic and humiliating for those who are targeted. Become objectified without consent and remove the ability to control who sees it, which could have serious consequences in real life: maybe their family sees it, maybe their boss sees it, maybe their significant other sees it, and maybe they all think it is real. Individuals could be threatened with sextortion or revenge porn generated by AI as a means of control and abuse, and many lack the financial or legal resources to seek justice in these situations.

Table 1: Overview of different categories of risks associated with deepfakes

Psychological Harm	Financial Harm	Societal Harm
• (S)extortion • Defamation • Intimidation • Bullying • Undermining trust	• Extortion • Identity theft • Fraud (e.g. insurance/payment) • Stock-price manipulation • Brand damage • Reputational damage	• News media manipulation • Damage to economic stability • Damage to the justice system • Damage to the scientific system • Erosion of trust • Damage to democracy • Manipulation of elections • Damage to international relations • Damage to national security

5 AI Security Principles and Provision Extensions

5.1 Secure Design

5.1.1 Principle 1: Raise awareness of AI security threats and risks

Primarily applies to: System Operators, Developers and Data Custodians. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 1 follow.

GenAI Deepfake Extension Provision 5.1.1.-1: System Operators and Developers shall have training and educational resources to help and provide users (customers) to understand the security threats and risks from GenAI LLMs in regard to deepfakes.

5.1.2 Principle 2: Design the AI system for security as well as functionality and performance

Primarily applies to: System Operators and Developers. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 2 follow.

GenAI Deepfake Extension Provision 5.1.2.-1: The User Interface Design shall encourage responsible use, such as integrating content filters, clearly labelling AI-generated content and informing users on limitations of reliability and accuracy of generated text and/or media.

5.1.3 Principle 3: Evaluate the threats and manage the risks to the AI system

Primarily applies to: System Operators and Developers. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 3 follow.

GenAI Deepfake Extension Provision 5.1.3.-1: System Operators and developers shall ensure they have access to continuous research to mitigate societal, safety and security risks and an ability to invest in effective mitigation measures when identified.

GenAI Deepfake Extension Provision 5.1.3.-2: System Operators and developers shall ensure GenAI systems are subject to risk assessments, and have mitigations needed to ensure safe operation are put in place before deployment.

5.1.4 Principle 4: Enable human responsibility for AI systems

Primarily applies to: System Operators and Developers. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 4 follow.

GenAI Deepfake Extension Provision 5.1.4.-1: System Operators and Developers shall have capabilities to demonstrate respect for Human Autonomy. AI systems should augment human capabilities, facilitate informed decision-making, and preserve human control. This is to enable societal and environmental well-being.

GenAI Deepfake Extension Provision 5.1.4.-2: System Operators and Developers shall have human oversight and monitoring. The GenAI system is monitored after deployment, and updates are implemented as needed to address any risks that materialize.

NOTE 1: The human oversight process should be able to respond to incorrect outputs and hallucinations.

NOTE 2: System Operators and Developers should enable cross-verification with trusted external sources to ensure accuracy of outputs from the GenAI system. This is dependent on GenAI Deepfake Extension Provision 5.1.1.-1.

5.2 Secure Development

5.2.1 Principle 5: Identify, track and protect the assets

Primarily applies to: Developers, System Operators and Data Custodians. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 5 follow.

GenAI Deepfake Extension Provision 5.2.1.-1: Developers, System Operators and Data Custodians shall inform users (customers) if the GenAI system is adapting and/or being trained with the assets and works of the user. This requires informed consent from the user, and they shall be able to opt out or opt-in of this at any time.

5.2.2 Principle 6: Secure the infrastructure

Primarily applies to: Developers and System Operators. Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 6.

NOTE: The developers and system operators should make available relevant details to Users of their GenAI of the measures and steps they take to secure infrastructure to raise confidence and trust.

5.2.3 Principle 7: Secure the supply chain

Primarily applies to: Developers, System Operators and Data Custodians. Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 7.

NOTE: The developers, system operators and data custodians should make available relevant details to Users of their GenAI of the measures and steps they take to secure the supply chain to raise confidence and trust.

5.2.4 Principle 8: Document data, models and prompts

Primarily applies to: Developers. Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 8.

GenAI Deepfake Extension Provision 5.2.4.-1: The Developer shall confirm that the data used to train the GenAI system have been legally accessed and/or licensed

NOTE 1: The developer should have a process to resolve infringement liabilities.

NOTE 2: This could be tested by generating an image or text and then conducting research by reverse image or text search to see how many infringement results obtained and then implementing measures to prevent it from (re)occurring.

NOTE 3: This principle requires human oversight and training to be effective. See principles 1 and 4.

5.2.5 Principle 9: Conduct appropriate testing and evaluation

Primarily applies to: Developers and System Operators. Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 9.

NOTE: This testing and evaluation could be done in the form of red team testing and/or adversarial testing.

EXAMPLE: Red team testing is meant to identify flaws in models, training data or outputs. For GenAI, this could be prompt testing to verify that the GenAI is not producing harmful or inappropriate results. This could include doing the same prompt in different languages, and if the controls are working, harmful or inappropriate results should not be produced. If they are, measures can be implemented to prevent it from occurring.

5.3 Secure Deployment

5.3.1 Principle 10: Communication and processes associated with End-users and Affected Entities

NOTE: As part of an organization's wider deployment practices, pre-deployment testing of AI systems is to be considered alongside the requirements below.

Existing provisions from ETSI EN 304 223 [1] apply. Provision extensions for Principle 10.

GenAI Deepfake Extension Provision 5.3.1.-1: An organization shall have in place a risk communication policy. Organization should understand their role and statutory responsibilities with regard to the GenAI systems they develop or manage. They should have in place appropriate risk management systems and be able to share information with other organizations as needed, for example, a national Market Surveillance Authority under the AI Act.

5.4 Secure Maintenance

5.4.1 Principle 11: Maintain regular security updates, patches and mitigations

Primarily applies to: Developers and System Operators

Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 11.

NOTE: The developers and system operators should have a policy in place to inform users and keep them updated about security updates, patches and measures being implemented to mitigate threats.

5.4.2 Principle 12: Monitor the system's behaviour

Primarily applies to: Developers and System Operators

Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 12.

NOTE: Monitoring the GenAI system's behaviour requires human agency and oversight. See principle 4.

5.5 Secure End of Life

5.5.1 Principle 13: Ensure proper data and model disposal

Primarily applies to: Developers and System Operators

Existing provisions from ETSI EN 304 223 [1] apply. No Provision extensions for Principle 13.

NOTE: Developers and System Operators should have appropriate processes and mechanisms in place to ensure compliance with GDPR articles that relate to the End-users. These include, but are not limited to, Article 15 GDPR: The right to access; Article 17 GDPR: The right to erasure; Article 19 GDPR: The right to portability.

Annex A (informative): Overview of Detection and Prevention of GenAI Deepfakes

A.1 Introduction

There are two distinct approaches to deepfake detection: manual and automatic detection. Manual detection requires a skilled person to inspect the video material and look for inconsistencies or cues that might indicate forgery. A manual approach can be feasible when dealing with low quantities of suspected materials, but it is not compatible with the scale at which audio-visual materials are used in modern society [i.9].

Automatic detection software can be based on a (combination of) detectable giveaways, some of which are AI-based themselves:

- Speaker recognition
- Voice liveness detection
- Facial recognition
- Facial feature analysis
- Temporal inconsistencies
- Visual artefacts
- Lack of authentic indicators

Several important cautions need to be kept in mind. One caution is that the performance of detection algorithms is often measured by benchmarking it against a common dataset with known deepfake videos. Also, detection evasion techniques using simple modifications in deepfake production techniques can drastically reduce the reliability of a detector.

Another problem detectors face is that audio-visual material is often compressed or reduced in size when shared on online platforms such as social media and chat apps. The reduction in the number of pixels and artefacts that sound, and image compression create can interfere with the ability to detect deepfakes.

While these will not stop the problem of deepfakes, they have the potential to reduce the harm and spread of deepfake material.

A.2 Reporting and Removal of Deepfake material

Victims of deepfakes, especially non-consensual sexually explicit media attacks, often note the difficulty of removing content from all potential sources. Victims describe the recurring nightmare of having the same content appear on multiple sites and the frustration/difficulties of having to solicit formal actions every time before it can be removed. Sign posting and ease of finding the right resources or places to report and to have this content removed are valuable.

List of Resources non-exhausted:

- The Federal Bureau of Investigation's (FBI) Internet Crime Complaint Centre (IC3) (https://www.ic3.gov/). This is from the USA.
- Report inappropriate content and abuse on social media platforms using the platforms' reporting procedures, though this becomes more difficult if the targeted victim doesn't have an account for that platform.
- If a victim is under 18 years of age, incidents can be reported to the National Centre for Missing and Exploited Children via their cyber tip line at https://report.cybertip.org. This is based in the USA.

- Google's Help Centre, a resource available via Google® that enables victims to remove fake pornography from Google searches https://support.google.com/websearch/answer/9116649?hl=en#:~:text=You%20or%20your%20authorized%20representative,representative%20submit%20in%20the%20form.

- StopNCII.org is a free tool designed to support victims of Non-Consensual Intimate Image (NCII) abuse and their partner network of victim advocates and non-profits around the world. https://stopncii.org/partners/global-network-of-partners/.

- Take It Down is a free service that can help users remove or stop the online sharing of nude, partially nude, or sexually explicit images or videos taken of them when they were under 18 years old. https://takeitdown.ncmec.org/.

- The Revenge Porn Helpline supports adult victims of intimate image abuse who live in the UK. They provide advice, guidance and support with the helpline to remove intimate content which has been non-consensually shared online. https://revengepornhelpline.org.uk/.

- INHOPE is a global network of hotlines working to eliminate CSAM from the internet. Since 1999, INHOPE has provided a safe and anonymous way for the public to report suspected CSAM online and ensure that it is reported to the country where the content is hosted. This guarantees that the illegal and harmful material can be removed from the internet as fast as possible. https://www.inhope.org/EN#hotlineReferral.

Annex B (informative): Trustworthy AI

B.1 Overview

Trustworthy AI is built upon three pillars that form the foundation of trustworthy AI as indicated in Figure B.1, and necessitate adherence throughout the entire AI system lifecycle as presented in ETSI TS 104 119 [i.10]:

1) Lawful: AI systems "shall rigorously comply with all applicable legal and regulatory frameworks", ETSI TS 104 119 [i.10]. This encompasses adherence to national, international, and European Union legislation, including but not limited to the General Data Protection Regulation (GDPR) [i.11] and relevant sector-specific directives. This adherence ensures AI operations remain within established legal parameters, safeguarding fundamental rights and societal values.

2) Ethical: Beyond strict legality, AI systems are required to embody and uphold established ethical principles and values. This component is instantiated through four core ethical principles:

   - Respect for Human Autonomy: AI systems should augment human capabilities, facilitate informed decision-making, and preserve human control.

   - Prevention of Harm: AI systems "shall be designed to preclude the infliction of physical, psychological, or economic detriment", ETSI TS 104 119 [i.10]. Proactive identification and mitigation of potential negative impacts are imperative.

   - Fairness: AI systems "shall operate equitably, actively mitigating unjustifiable bias and discrimination, thereby ensuring impartial treatment across individuals and groups", ETSI TS 104 119 [i.10] .

   - Explicability: The processes, functionalities, and decision-making mechanisms of AI systems "shall exhibit transparency, interpretability, and comprehensibility to relevant stakeholders, thereby enabling scrutiny and accountability", ETSI TS 104 119 [i.10].

3) Robust: AI systems are required to possess both technical and societal robustness. This necessitates that they be reliable, secure, and resilient, capable of consistent and safe operation within diverse real-world environments, while also adapting responsibly to evolving societal contexts. Technical robustness pertains to attributes such as accuracy, dependability, and cybersecurity, whereas societal robustness encompasses broader ethical considerations and societal impact.

The Trustworthy AI pillars can be mapped to GenAI to help mitigate the potential for harm associated with it.

NOTE: These same principles for GenAI being trustworthy can be applied similarly to Agentic AI.

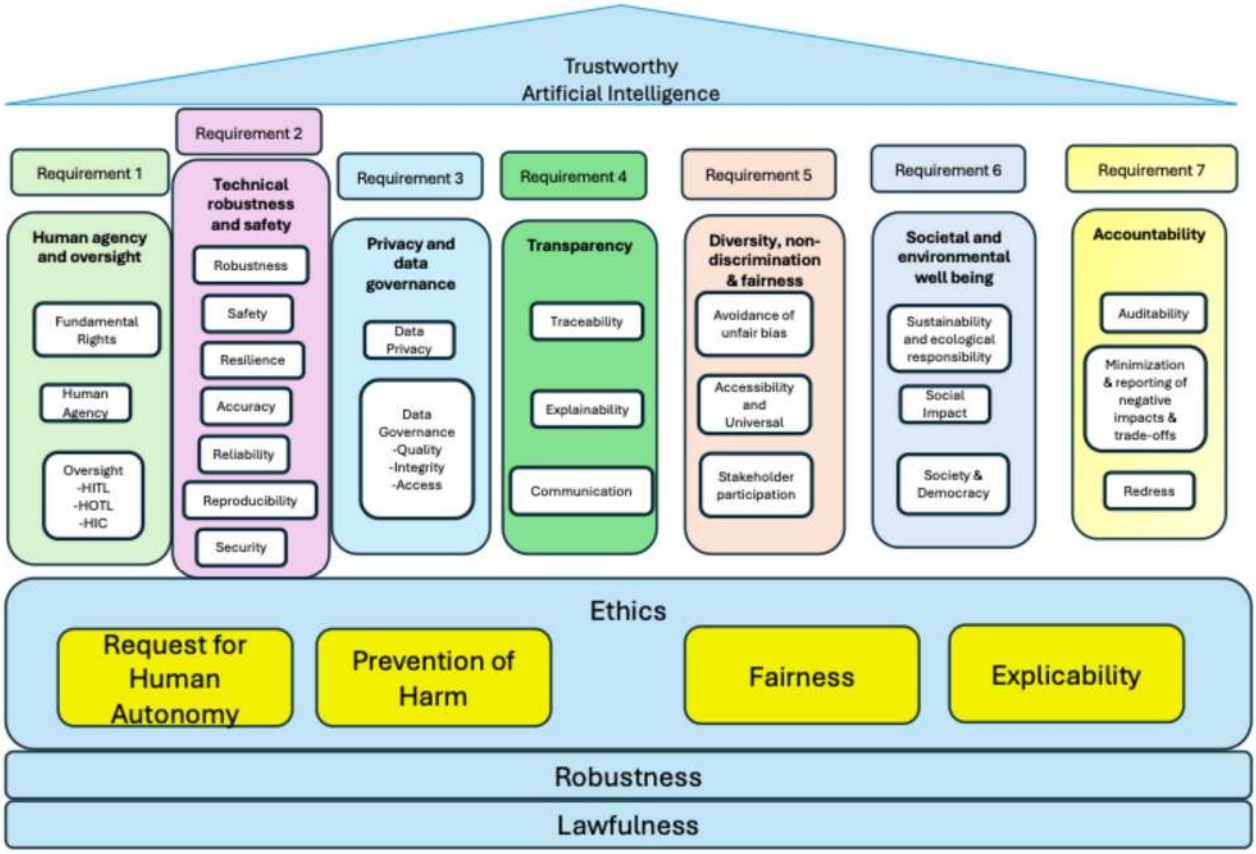


Figure B.1: Trustworthy AI pillars, requirements and characteristics

B.2 Mapping of GenAI to Trustworthy AI

B.2.1 Overview

The requirements of trustworthy AI apply to GenAI. By showing that a GenAI system meets the requirements for trustworthy AI, it can aid in meeting many of the principles and requirements under the various regulations and legalizations applicable to AI.

B.2.2 Table of Mapping

The controls and methods for mapping of GenAI to Trustworthy AI are drawn from clause 5.

Table B.1: Mapping of GenAI to Trustworthy AI

	Requirement 1 Human Agency and oversight	**Requirement 2 Technical robustness and safety**	**Requirement 3 Privacy and data governance**	**Requirement 4 Transparency**	**Requirement 5 Diversity, non-discrimination & fairness**	**Requirement 6 Societal and environmental well being**	**Requirement 7 Accountability**
GenAI controls and methods for requirements	Have a human oversight process in place to be able to respond to incorrect outputs and hallucinations.	Test and refine the system continually.	Use of federated learning.	Data used to train the algorithm has been legally accessed or licensed.	Training and Education to help users understand the limitations of GenAI LLMs.	User Interface Design should encourage responsible use, such as integrating content filters, clearly labelling AI-generated content and informing users on limitations of reliability and accuracy.	Risk Communication.
	Cross-Verification with trusted external sources to ensure accuracy of outputs.	Model fine tuning.	Use of differential privacy methods.	From ETSI TS 104 119 [i.10]: *"The processes, functionalities, and decision-making mechanisms of AI systems shall exhibit transparency, interpretability, and comprehensibility to relevant stakeholders, thereby enabling scrutiny and accountability."*	Ensuring diversity/inclusion for example adopting universal design, ensuring accessibility, and providing relevant stakeholders with education and support.	From ETSI TS 104 119 [i.10]: "*AI systems shall rigorously comply with all applicable legal and regulatory frameworks. This adherence ensures AI operations remain within established legal parameters, safeguarding fundamental rights and societal values."*	Organizations understand their role with regard to the systems they develop or manage, put in place appropriate risk management systems, and share information with other organizations as needed.
	Human Oversight and Monitoring - System use is monitored after deployment, and updates are implemented as needed to address any risks that materialize.	Use of Retrieval-Augmented Generation.	Aim to anonymize models whenever it does not compromise their intended purpose.			Respect for Human Autonomy: AI systems should augment human capabilities, facilitate informed decision-making, and preserve human control.	
		Use of Automatic Validation Mechanisms.	Incorporate solutions to prevent the disclosure of confidential personal data by AI models.				

		Secure Coding Practises.					
		Continuous research to mitigate societal, safety and security risks and investment in effective mitigation measures when identified.					
		Systems are subject to risk assessments, and mitigations needed to ensure safe operation are put in place before deployment.					

Annex C (normative): Extension Provisions for Conformance assessment for AI

C.1 Overview

Annex C provides test scenarios for the extension provisions in clause 5 for the conformance assessment for AI (ETSI EN 304 223 [1]). The relevant base documents Annex C builds upon are ETSI TS 104 216 [i.4] and ETSI TR 104 128 [i.2].

C.2 Extension Provisions Test scenarios for AI

C.2.1 TSO 5.1.1: Raise awareness of AI security threats and risks

C.2.1.1 Test Case GenAI Deepfake Extension Provision 5.1.1.-1

Test purpose

Verify inclusion and regular update of the security threats and risks from GenAI LLMs in regard to deepfakes in cybersecurity training.

Test Method

Review cybersecurity training materials and the training maintenance/update record (e.g. version history, change log, or annual review sign-off). Interview the training owner to confirm the update cadence and triggers (e.g. after major GenAI system changes or deepfake incidents).

Assignment of verdict

Pass

Training materials include GenAI security topics relevant to the organization (e.g. prompt injection, data leakage, model theft/extraction, supply-chain risks, misuse/abuse cases) and evidence shows the content has been reviewed and updated within the last 12 months.

Fail

Training materials do not include GenAI security topics, or there is no evidence that the GenAI security content has been reviewed/updated within the last 12 months.

C.2.2 TSO 5.1.2: Design the AI system for security as functionality and performance

C.2.2.1 Test Case GenAI Deepfake Extension Provision 5.1.2.-1

Test Purpose

Verify that the GenAI system user interface design encourages responsible use.

Test Method

Review design documents, implementation evidence and test results. Confirm that mechanisms such as content filters, clear labelling of AI-generated content, and user information on the limitations of reliability and accuracy of generated text and/or media are implemented.

Assignment of verdict

Pass

Design and implementation evidence demonstrates that responsible-use mechanisms are in place, including appropriate content filters, clear labelling of AI-generated content, and user information on the limitations of reliability and accuracy of generated text and/or media. Test results demonstrate that these mechanisms function as intended.

Fail

Responsible-use mechanisms are absent, incomplete, or not implemented; or test results do not demonstrate that the implemented mechanisms function as intended.

C.2.3 TSO 5.1.3: Evaluate the threats and manage the risks to the AI system

C.2.3.1 Test Case GenAI Deepfake Extension Provision 5.1.3.-1

Test Purpose

Verify that System Operators and developers have access to continuous research to mitigate societal, safety and security risks and the ability to invest in effective mitigation measures when identified.

Test Method

Review notes, communications, research access records, review records and action trackers relating to societal, safety and security risks. Confirm whether identified risks result in documented decisions and, where appropriate, investment in mitigation measures.

Assignment of verdict

Pass

Evidence demonstrates that System Operators and developers have regular access to and review of relevant research, for example at least quarterly, within the last 12 months. Reviews are proactive and not solely triggered by incidents. The reviews result in documented outcomes, including risk decisions, mitigation actions, assigned owners and tracked completion of actions.

Fail

No defined approach or cadence for accessing and reviewing relevant research exists; no evidence of review within the last 12 months is available; or identified risks do not result in documented decisions, mitigation actions, assigned owners or tracked completion of actions.

C.2.3.2 Test Case GenAI Deepfake Extension Provision 5.1.3.-2

Test Purpose

Verify that GenAI systems are subject to risk assessments before deployment, and that mitigations needed to ensure safe operation are implemented before deployment.

Test Method

Review pre-deployment risk assessment documentation, risk management plans, risk registers, mitigation plans, release approval records, sign-off records and action trackers. Confirm that required mitigations were identified, implemented and verified before deployment, and that residual risks were documented and approved.

Assignment of verdict

Pass

Evidence demonstrates that a risk assessment was completed before deployment, identified risks were evaluated, required mitigations were implemented and verified before deployment, and residual risks were documented and approved. Where periodic reassessment is required, evidence shows that reassessments are performed according to the defined cadence and result in documented decisions, assigned owners and tracked actions.

Fail

No pre-deployment risk assessment is available; required mitigations are not implemented and verified before deployment; residual risks are not documented or approved; or periodic reassessments, where required, are not evidenced by documented decisions, assigned owners and tracked actions.

C.2.4 TSO 5.1.4: Enable human responsibility for AI systems

C.2.4.1 Test Case GenAI Deepfake Extension Provision 5.1.4.-1

Test Purpose

Verify that System Operators and Developers have documented and implemented capabilities that demonstrate respect for human autonomy.

Test Method

Review system architecture, design documentation, user interface specifications and implementation evidence for elements that respect human autonomy. This includes tools and controls that augment human capabilities, facilitate informed decision-making and preserve human control.

Assignment of verdict

Pass

Documentation and implementation evidence demonstrate that the system includes effective mechanisms to support human autonomy, such as user control over key actions, clear information for informed decision-making, the ability to review or reject outputs, and escalation to human oversight where appropriate.

Fail

No documented or implemented mechanisms are available to demonstrate support for human autonomy, informed decision-making or meaningful human control.

C.2.4.2 Test Case GenAI Deepfake Extension Provision 5.1.4.-2

Test Purpose

Verify that System Operators and Developers have human oversight and monitoring. The GenAI system is monitored after deployment, and updates are implemented as needed to address any risks that materialize.

Test Method

Review the documented human oversight and monitoring process, monitoring records, issue logs, escalation records, change management records and evidence of updates implemented to address risks.

Assignment of verdict

Pass

Human oversight and monitoring methods are documented, implemented and tested. Evidence shows that post-deployment monitoring is performed, identified risks or incidents are reviewed by responsible personnel, and required updates are tracked and implemented.

Fail

Human oversight or monitoring methods are missing, not implemented, not tested, or do not result in tracked updates when risks materialize.

C.2.5 TSO 5.2.1 Identify, track and protect the assets

C.2.5.1 Test Case GenAI Deepfake Extension Provision 5.2.1.-1

Test Purpose

To verify that a system and/or process is in place to inform users (customers) if the GenAI system is adapting and/or being trained with the assets and works of the user. This requires informed consent from the user, and they shall be able to opt out or opt-in of this at any time.

Test Method

Confirm and test the system and/or process that communicates with users about consent for the use of their works or assets. Test whether users can grant, withdraw and change consent, and whether the system reflects the consent state correctly.

Assignment of verdict

Pass

Evidence demonstrates that users are informed before their assets or works are used for adaptation or training, that informed consent is recorded, and that users can opt in, opt out or withdraw consent at any time. System records show that consent choices are enforced.

Fail

User notification is missing or incomplete; informed consent is not recorded; users cannot opt in, opt out or withdraw consent; or the system does not enforce the recorded consent state.

C.2.6 TSO 5.2.4 Document data, models and prompts

C.2.6.1 Test Case GenAI Deepfake Extension Provision 5.2.4.-1

Test Purpose

Verify that the data used to train the GenAI system have been legally accessed and/or licensed.

Test Method

Review documentation, audit logs and data lineage records identifying the origin of data used to train the GenAI system. Verify that appropriate access rights, licences, permissions or other legal bases exist for the use of the data.

Assignment of verdict

Pass

Data lineage documentation identifies the sources of training data, and evidence demonstrates that the data was legally accessed and/or licensed for the intended training purpose.

Fail

Data sources are not documented, data lineage is incomplete, or evidence of legal access, licence, permission or other legal basis for the training data is missing.

C.2.7 TSO 5.3.1 Communication and processes associated with End-users and Affected Entities

C.2.7.1 Test Case GenAI Deepfake Extension Provision 5.3.1.-1

Test Purpose

Verify that the organization has a risk communication policy covering its role, statutory responsibilities, risk management processes and information sharing obligations for GenAI systems it develops or manages.

Test Method

Review the risk communication policy, role and responsibility assignments, statutory responsibility analysis, risk management procedures, communication templates, escalation paths, and records of internal or external information sharing where applicable.

Assignment of verdict

Pass

A documented and accessible risk communication policy exists and covers organizational roles, statutory responsibilities, risk management processes, escalation paths and information sharing with relevant organizations or authorities where needed. Evidence includes approved policy documentation, assigned owners, communication channels, review records and examples of information sharing where applicable.

Fail

The risk communication policy is missing, incomplete, inaccessible, or does not cover organizational roles, statutory responsibilities, risk management processes, escalation paths or information sharing where needed; or no evidence is available for assigned owners, review records or applicable information sharing.

History

Version	Date	Status
V1.1.1	September 2026	Publication